Identifying Risk Factors and Vulnerabilities (Part 2)

Risk factors of material, software, organizational and human resources — and how to extract them from internal reports

420-1C2-DW Threats and Risks · **AEC** (Attestation d'études collégiales) Cybersecurity: Prevention and Intervention (LEA.D8)
Class 9 · Thursday, November 12, 2026 · 6:00 – 10:00 pm · Online
Topic 4 — Part 2 · Competency EZ02, criteria 3.3 and 3.4

⚖️ Use of this material is governed by the Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together ! ALL Rights Reserverd

The one fact to remember tonight

Asset + condition + evidence

A risk factor is a fact about the organization, written with its evidence. Every row you write tonight names the asset, the condition, and the document — with its location — that proves it.

The hour — four lessons on the clock

0:00 – 0:04	Opening — the one fact, objectives, legal frame
0:04 – 0:20	Lesson 1 — Risk factors of material, software, organizational and human resources
0:20 – 0:36	Lesson 2 — Internal information sources
0:36 – 0:50	Lesson 3 — Careful analysis: extracting risk factors from a report
0:50 – 0:58	Lesson 4 — Workshop: the list of risk factors for Kalmia
0:58 – 1:00	Closing — what comes next (Classes 10 and 11, Lab 2, Lab 3, Quiz 3)

By the end of this hour you will be able to

- Define risk factor, vulnerability and predisposing condition, and classify a risk factor as material, software, organizational or human (EZ02, criterion 3.3).
- Name the five types of internal information sources and state what each one can reveal and what it cannot (criterion 3.4).
- Judge a source by five questions: its date, its scope, its author, its method and its evidence.
- Apply the seven-step reading method to extract risk factors from a report, each with its location and a confidence level.
- Consolidate risk factors from several sources into one list without losing a source and without hiding an unknown.

Competency EZ02

Element 3 — identification of risk factors

3.3 Main risk factors of material, software, organizational and human resources

3.4 Careful analysis of various internal sources

From the Class 6 lists to tonight's evidence pack

Class 6
24 NA- · 34 SW- · 16 VS- rows

→

Tonight's pack
16 internal documents: PT · CR · IR · MR · PS

→

Tonight's outputs
4 files from Examples 1 to 4

→

Workshop list
34 risk factors + 5 unknowns

→

Lab 3 (Nov 14)
likelihood × impact

Type of source	Documents in the pack
Penetration test (PT)	PT-2026-05
Compliance reports (CR)	CR-2026-01, CR-2026-02
Incident reports (IR)	IR-INC-01 to IR-INC-05
Monitoring reports (MR)	MR-01 to MR-05
Policies, procedure, contract (PS)	PS-01, PS-02, PS-03

Legal frame for tonight

- Every finding, weakness or gap about an organization is confidential, without time limit (s. 7.5)
- Course work is not an audit, an assessment or an attestation; never sign as an assessor (s. 7.5)
- Treat every log and alert record as personal information (s. 7.2)
- Fictional or synthetic data only in labs (s. 6.7); a test needs a written scope (s. 7.7.2)
- A course exercise is not forensic work (s. 7.8); check links before opening them (s. 14.2, Annex C)

Cyber.SoHo Legal Notice v2.0

Full terms: cyber-soho.github.io/prevmon (Legal Notice, Terms of Use and Acceptable Use Policy). Version 2.0 supersedes version 1.0.

Criminal Code ss. 342.1, 342.2, 430(1.1), 184

↗ Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

1

LESSON 1 · 0:04 – 0:20

Risk factors of material, software, organizational and human resources

What a risk factor is, the four resource categories, the classification rule and the cause chain

Risk factor — the definition we use

NIST (National Institute of Standards and Technology) SP (Special Publication) 800-30 Rev. 1

A characteristic used in a risk model as an input to determining the level of risk in a risk assessment.

- Five typical risk factors: threat, vulnerability, impact, likelihood, predisposing condition
- Lab 2 covers the threats; Topic 5 covers likelihood and impact
- Tonight: the two risk factors that live inside the organization

Vulnerability and predisposing condition

V Vulnerability

A weakness in a system, its security procedures, internal controls or implementation that a threat source could exploit or trigger.

Kalmia: the NAS-01 admin password stored in a file readable by all staff.

PC Predisposing condition

A condition of the organization, process, architecture or system that makes harm more (or less) likely.

Kalmia: the flat head-office network — every compromised device can reach NAS-01.

Four resource categories (EZ02, criterion 3.3)

M Material

Physical items and places: computers, servers, network devices, power, rooms

S Software

Operating systems, applications, firmware, cloud services — and their configuration

O Organizational

Roles, processes, policies, procedures, contracts, budget, documentation

H Human

People: what they know, what they do, how many are available

Purpose 1: completeness (scans see programs and ports). Purpose 2: each category calls a type of control in Topic 6.

Material resources — what to look for

- Age and support of hardware; spare parts
- Signs of failure: disk warnings, battery tests, temperature alarms
- Single points of failure: one disk, one link, one power supply
- Environment: heat, dust, water, unstable power
- Physical protection: the lock is material; leaving it open is human
- Portable and unauthorized devices

M **At Kalmia**

NAS-01 disk 3: 48 reallocated sectors, rising (MR-03)

UPS-HQ battery: 4 min of the 15 needed (MR-04)

Closet: no ventilation, 58 °C on Oct 9 (MR-03)

One internet link per café (INC-03)

Software — what to look for

- End of support and missing patches (Class 6)
- Insecure configuration: default or shared credentials, clear-text administration, unnecessary services
- Missing security functions: **MFA** (multi-factor authentication), lockout, logging
- Unknown versions — a version nobody can name is a finding
- Configuration is software: values stored in a program or a device

S **At Kalmia**

The Class 6 SW- rows stay in the list

Legacy authentication (**IMAP** [Internet Message Access Protocol]) on commandes@ (MR-02)

MFA on 2 of 31 Microsoft 365 accounts (MR-02)

Organizational resources — what to look for

- A policy or procedure missing, outdated, never approved or not applied
- A responsibility that nobody holds
- A contract that leaves a gap between supplier and client
- No periodic review (accounts, permissions, backups, findings)
- Declarations to third parties that do not match reality
- A legal obligation that is not met

At Kalmia

No incident response plan

No offboarding procedure (INC-04)

InfoNord contract: 'the server and the firewall' (PS-03)

Backup procedure: 2023 draft (PS-02)

Human resources — what to look for

- Knowledge: awareness of phishing and fraud
- Behaviour: shared passwords, passwords stored in files, visitors let in
- Availability: key-person dependency, workload, turnover
- Insiders: current or former staff who keep access
- Ethics: describe the condition of a role, never a person to blame

H **At Kalmia**

9 of 30 entered their password (PT-02)

One **NAS** (network-attached storage) admin password shared by four people

One half-time **IT** (information technology) coordinator

Café turnover about 40% per year

The classification rule: what must change?

M Material

A physical item must be repaired, replaced or added

S Software

A program, firmware or setting must change

O Organizational

A rule, document, role, contract or process must change

H Human

What people know, do, or how many are available must change

One row = one condition. 'Key left in the door' (human) + 'closet left unlocked for the cleaners' (organizational) = two rows, linked.

One observation, several rows: the cause chain

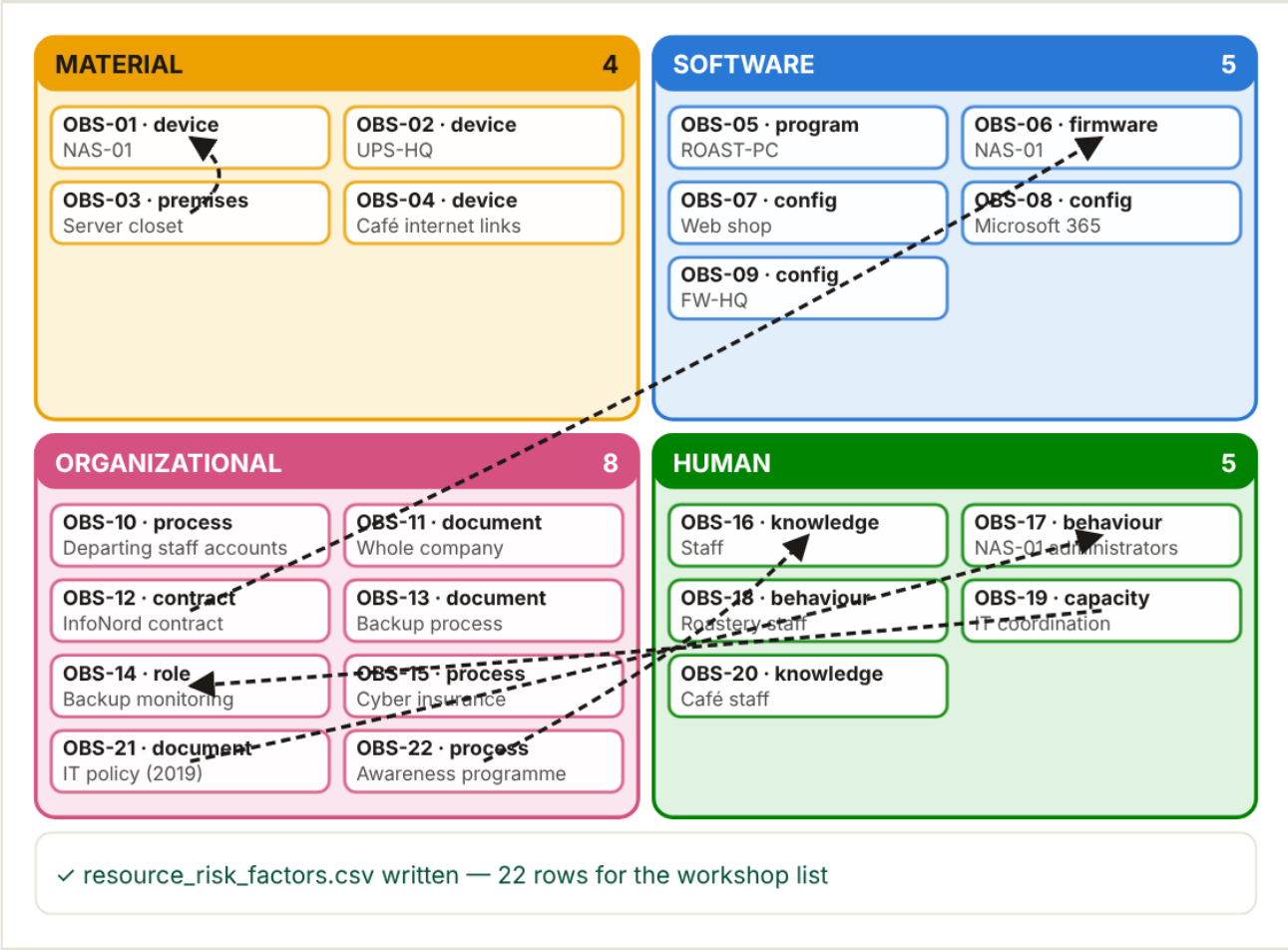


Different treatments: an update · a contract amendment · a second trained person. INC-04: the export was the event; the missing offboarding procedure is the risk factor.

Real-life example 1 — Kalmia's observations in four categories

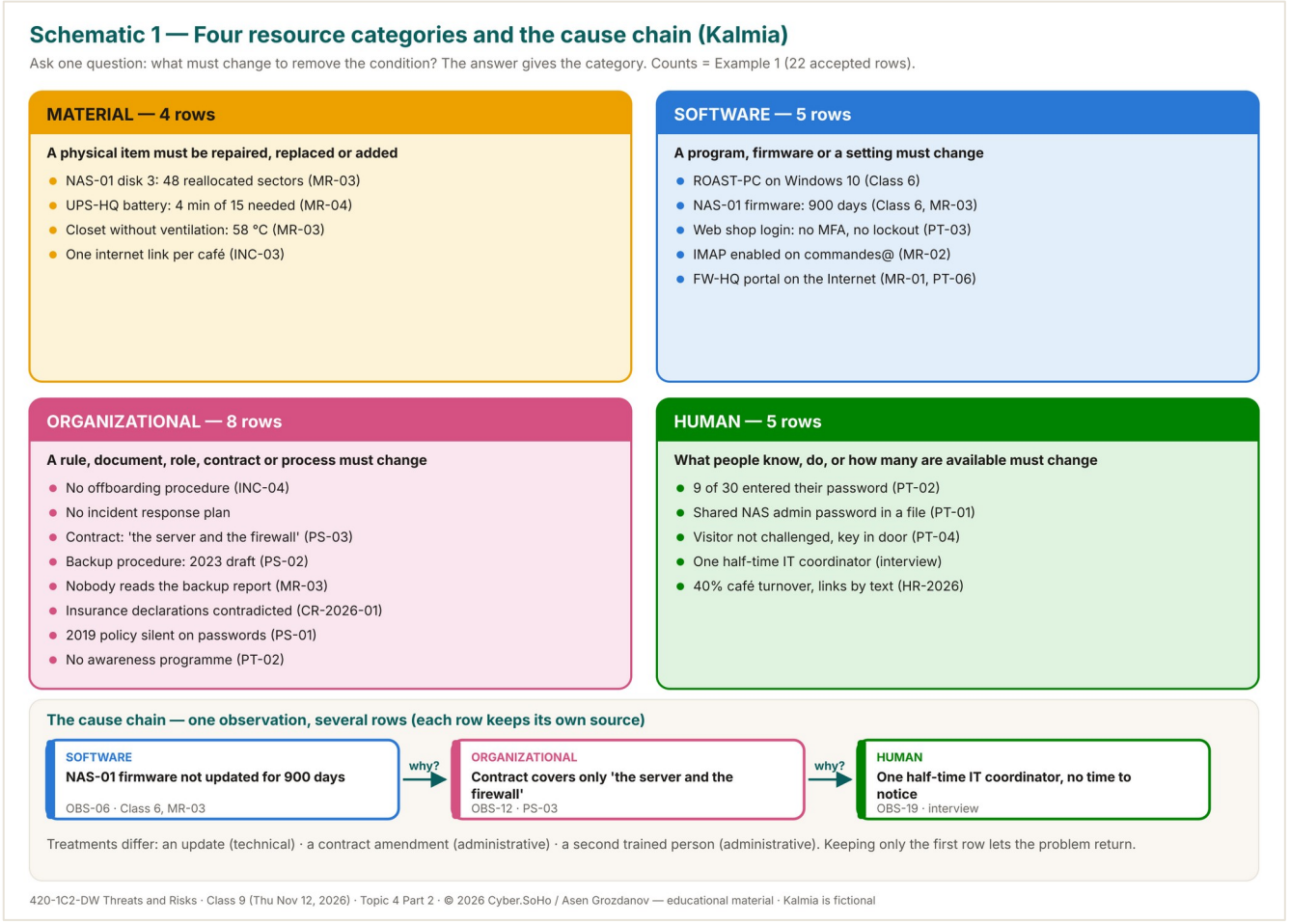
Category	Rows	Kalmia examples (source)
Material	4	NAS-01 disk 3 warning (MR-03) · UPS-HQ battery 4 min (MR-04) · closet without ventilation, 58 °C (MR-03) · one internet link per café (INC-03)
Software	5	ROAST-PC on Windows 10 · NAS-01 firmware 900 days · web shop login without **MFA** or lockout (PT-03) · **IMAP** on commandes@ (MR-02) · FW-HQ portal on the Internet (MR-01, PT-06)
Organizational	8	No offboarding (INC-04) · no incident response plan · contract gap (PS-03) · draft backup procedure (PS-02) · nobody reads the backup report (MR-03) · insurance declarations contradicted (CR-2026-01) · 2019 policy silent on passwords (PS-01) · no awareness programme
Human	5	9 of 30 staff entered their password (PT-02) · shared **NAS** admin password in a file (PT-01) · visitor not challenged, key in the door (PT-04) · one half-time **IT** coordinator · 40% café turnover with schedule links by text
Rejected	1	OBS-23 'The cafés are probably not secure' — no source, no observable condition: an opinion, not a risk factor

Code example 1 (Python) — classifying the observations



kalmia_resource_classifier.py — end of the recorded run: 4 material, 5 software, 8 organizational, 5 human, 1 rejected, 5 cause chains (arrows).

Schematic 1 — four categories and the cause chain



*Download it as **SVG** (Scalable Vector Graphics) or **PNG** (Portable Network Graphics) from the lecture page (Lesson 1 → Schematic 1).*

Videos — Lesson 1



Hardware Vulnerabilities — CompTIA Security+ SY0-701 (2.3)

6:27 min

Professor Messer · https://www.youtube.com/watch?v=TaTaEvqjjDM



Physical Attacks — CompTIA Security+ SY0-701 (2.4)

4:04 min

Professor Messer · https://www.youtube.com/watch?v=oIpOuTX2HRs



Security Procedures — CompTIA Security+ SY0-701 (5.1)

7:02 min

Professor Messer · https://www.youtube.com/watch?v=vJINnOZyQNg



Security Awareness — CompTIA Security+ SY0-701 (5.6)

6:45 min

Professor Messer · https://www.youtube.com/watch?v=W_Npxwk4fbI

Checked on November 10, 2026 — every video exists and is 15 minutes or shorter. Check each link on VirusTotal before opening it (Legal Notice, s. 14.2).

LESSON 2 · 0:20 – 0:36

2

Internal information sources

Penetration test reports, compliance reports, incident reports, network and host monitoring reports, policies and standards

Internal and public information sources

Public sources (Class 5)

Newsletters, advisories, **CVE** (Common Vulnerabilities and Exposures) records, MITRE ATT&CK: what attackers do in general.

Internal sources (tonight)

What is true inside one organization: weaknesses, incidents, rules and whether they are applied.

- EZ02 lists: penetration test, compliance, incident and monitoring reports; policies and standards
- **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-30 Task 1-4: identify the sources of threat, vulnerability and impact information first
- Internal sources are confidential (Legal Notice, s. 7.5)

Penetration test reports (1/2) — what the report contains

- Header: client, report **ID** (identifier), dates, authorization (rules of engagement)
- Executive summary for management
- Scope and method; limitations
- Findings: **ID**, severity, asset, weakness, evidence, contributing factors, recommendation
- Positive observations; appendices with the evidence
- Scan = potential weaknesses; penetration test = proven exploitable

PT-2026-05

Nordet Sécurité inc. (external)

Tested May 11–15, 2026

Rules of engagement signed by Nadia Roy, May 4

Written scope required (s. 7.7.2, Annex D)

Penetration test reports (2/2) — what it reveals, and what it cannot

Reveals

Weaknesses proven exploitable; attack paths that cross categories (a password in a file + an open administration port); organizational causes in the contributing factors.

Cannot reveal

Anything outside scope or time window (ROAST-PC and the café networks were excluded → unknowns). It describes May. Its severity is the tester's rating, not Kalmia's risk level.

Compliance reports (1/2) — what they are

- A statement, requirement by requirement, of whether a law, regulation, standard or contract is met
- Forms: self-assessment, external audit, attestation, questionnaire to a client or insurer
- Québec private-sector privacy law (Law 25), overseen by the **CAI** (Commission d'accès à l'information du Québec): person in charge (s. 3.1), governance policies (s. 3.2), **PIA** (privacy impact assessment) (s. 3.3), notice of serious-injury incidents (s. 3.5), incident register (s. 3.8)
- **PCI DSS** (Payment Card Industry Data Security Standard): merchants accepting cards confirm compliance every year (often an **SAQ** [Self-Assessment Questionnaire])

Limit

A self-assessment is a declaration — the weakest evidence until another source confirms it

↗ CAI — Commission d'accès à l'information du Québec
↗ Act P-39.1 (LégisQuébec)

Compliance reports (2/2) — Kalmia's two documents

CR

CR-2026-02 — Law 25 self-assessment (Oct 16)

No governance policy · person in charge not designated in writing nor published · INC-04 risk-of-serious-injury assessment not documented · no retention rule for 18,500 loyalty records

CR

CR-2026-01 — cyber-insurance questionnaire (June 20)

Declares: **MFA** (multi-factor authentication) for all remote access · offline backups · no end-of-life systems.

The evidence contradicts all three (PT-05, MR-03, ROAST-PC on Windows 10).

Each nonconformity is an organizational risk factor; each contradicted declaration is a risk factor too (KRF-23).

Incident reports — read the condition, not the event

- Timeline, detection, impact, actions, root cause, contributing factors, lessons learned
- **NIST SP** 800-61 Rev. 3 (April 2025): lessons learned feed risk management
- Strong evidence: the condition already produced harm
- Limit: only what was detected — no incident report is not 'no risk'

At Kalmia

INC-04: export of 18,500 records = the event

No offboarding procedure = the risk factor

INC-02: no written check of new banking details

INC-04 found two weeks later

Network and host monitoring reports

- Firewall reports, sign-in logs, system logs, backup reports, endpoint consoles, hardware and **UPS** (uninterruptible power supply) tests
- **NIST SP** 800-92 (log management) · **NIST SP** 800-137 (continuous monitoring)
- Show current conditions that tests rarely show
- Limits: a tool sees only what it monitors; a report nobody reads protects nothing
- Logs contain personal information (s. 7.2)

At Kalmia (October)

41,870 blocked logins on the FW-HQ portal (MR-01)

Unannounced vendor night sessions (MR-01)

MFA on 2 of 31 accounts (MR-02)

11 failed backup nights, unnoticed (MR-03)

ROAST-PC not managed (MR-05)

Policies and standards — four questions

- Policy = management's approved intent and rules · Standard = mandatory measurable requirement
- Procedure = the steps · Guideline = advice
- Ask: Does it exist? Is it approved and current? Is it known? Is it applied — with what evidence?
- Compare with **NIST CSF** (Cybersecurity Framework) 2.0, **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001, **CIS** (Center for Internet Security) Controls v8.1, Cyber Centre baseline controls

At Kalmia

PS-01 (2019): 90-day password changes — **NIST SP** 800-63B-4 says verifiers shall not require periodic changes

PS-02: draft, never applied

PS-03: NAS-01 has no patch owner

No incident response plan (baseline control 1)

Judging a source: five questions

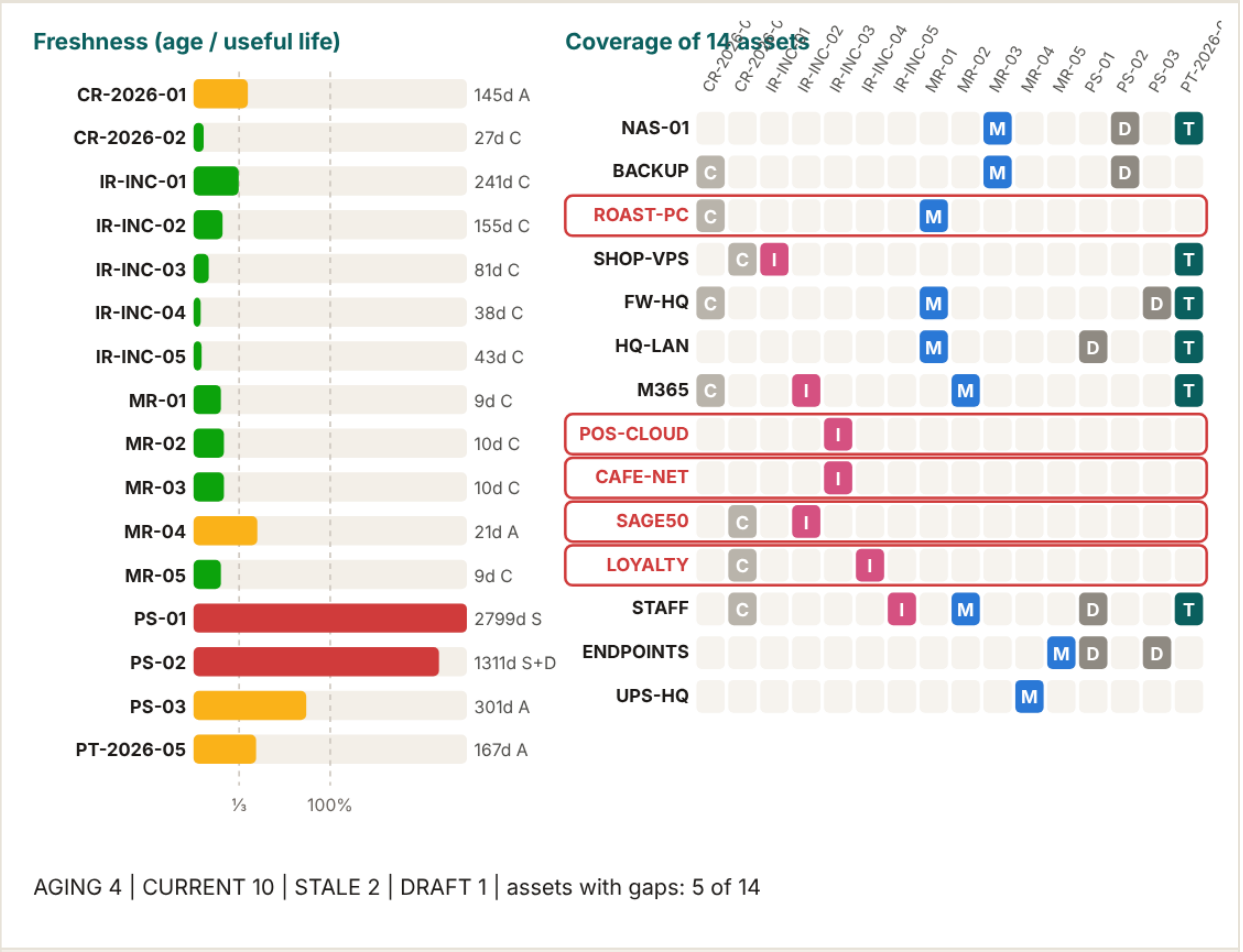


Date	Scope	Author	Method	Evidence
Age compared with the useful life of its type	What it covers — and what it excludes	Internal or external; independent or not	Tested > monitored > incident > documented > declared	Can someone else verify it?

Real-life example 2 — Kalmia's internal source register

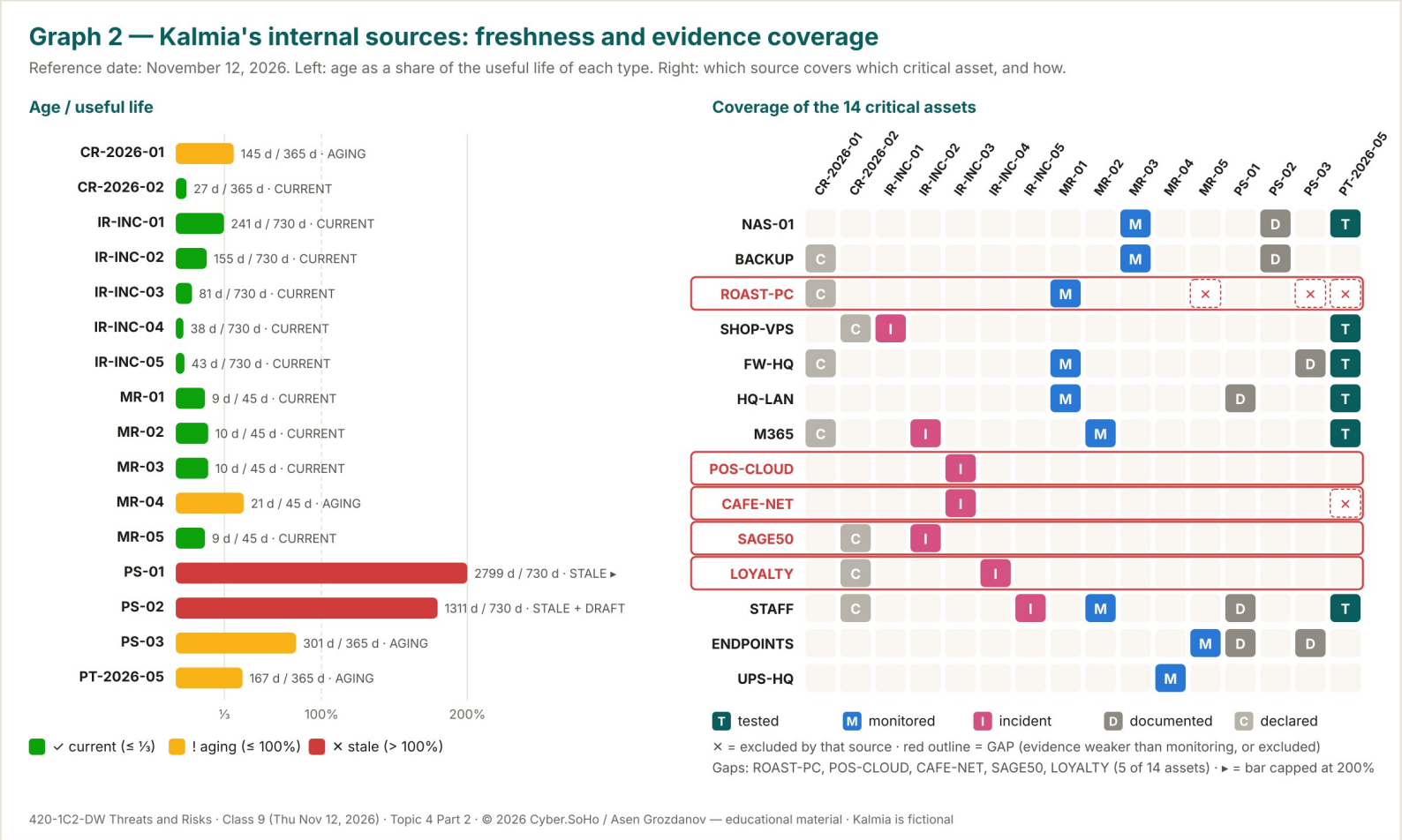
Type	Documents	Author / method	Freshness on November 12
Penetration test	PT-2026-05	Nordet Sécurité (external) · tested	AGING — 167 days of a 365-day useful life
Compliance	CR-2026-01 (insurance), CR-2026-02 (Law 25)	Kalmia (internal) · declared	AGING · CURRENT
Incidents	IR-INC-01 to IR-INC-05	Kalmia (internal) · incident	CURRENT (all five)
Monitoring	MR-01 to MR-05	InfoNord (external) and Lucas Martin · monitored	CURRENT, except MR-04 (**UPS**, 21 days: AGING)
Policies, procedures, contract	PS-01, PS-02, PS-03	Kalmia and InfoNord · documented	STALE (2019 policy) · STALE + DRAFT (2023 procedure) · AGING (contract)

Code example 2 (PowerShell 7) — building the register



Build-KalmiaSourceRegister.ps1 — freshness of 16 sources (left) and coverage of 14 assets (right); red rows are gaps.

Graph 2 — freshness of the sources and coverage of the assets



10 current · 4 aging · 2 stale · 1 draft — gaps: ROAST-PC, POS-CLOUD, CAFE-NET, SAGE50, LOYALTY.

Videos — Lesson 2



Penetration Tests — CompTIA Security+ SY0-701 (5.5) — 5:29 min

Professor Messer · https://www.youtube.com/watch?v=wEMzVfwBiWY



Compliance — CompTIA Security+ SY0-701 (5.4) — 8:06 min

Professor Messer · https://www.youtube.com/watch?v=IjJf4jLtONQ



Incident Planning — CompTIA Security+ SY0-701 (4.8) — 6:50 min

Professor Messer · https://www.youtube.com/watch?v=CYFe16lCRMk



Security Monitoring — CompTIA Security+ SY0-701 (4.4) — 10:27 min

Professor Messer · https://www.youtube.com/watch?v=np2WI_rM-Ok



Security Policies — CompTIA Security+ SY0-701 (5.1) — 11:02 min

Professor Messer · https://www.youtube.com/watch?v=5kY9kvzeWjA

Checked on November 10, 2026 — every video exists and is 15 minutes or shorter. Check each link on VirusTotal before opening it (Legal Notice, s. 14.2).

LESSON 3 · 0:36 – 0:50

3

Careful analysis: extracting risk factors from a report

Fact, inference, recommendation and limitation; the seven-step reading method; risk factor statements; corroboration and confidence

Fact, inference, recommendation, limitation

F

Fact

Observation with verifiable evidence → becomes a risk factor

I

Inference

Conclusion drawn from facts → verify before use

R

Recommendation

Proposed action → kept for Lab 4, never a risk factor

L

Limitation

Not examined → recorded as an unknown

*Most frequent error: 'NAS-01 needs **MFA** (multi-factor authentication)' — a recommendation written as a risk factor.*

The seven-step reading method



1 Identify	2 Limits	3 Extract	4 Translate	5 Classify	6 Corroborate	7 Record
type, author, date, scope, authorization	exclusions → unknowns	atomic facts with location	asset — condition (source)	category, type, cause chain	confidence level	list row, confidential

Steps 1 and 2 on PT-2026-05

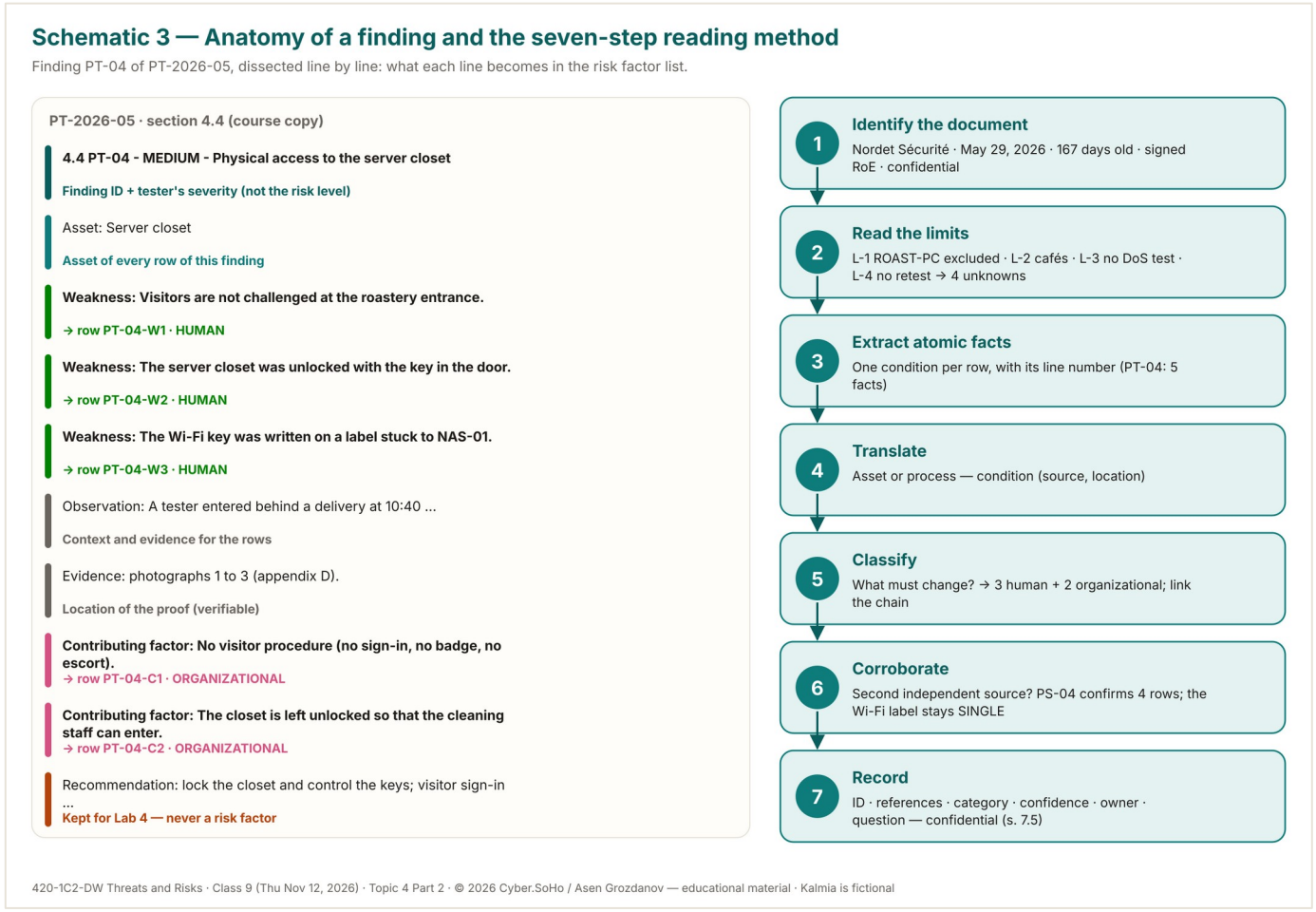
Step 1 — identify

Nordet Sécurité (external) · report May 29, 2026 · tested May 11–15 · rules of engagement signed May 4 · confidential · 167 days old on November 12.

Step 2 — limits

L-1 ROAST-PC excluded · L-2 café networks out of scope · L-3 no denial-of-service test · L-4 no retest → four unknowns. Findings still open in November → KRF-28.

Steps 3 to 5 — from one finding to five rows



PT-04 dissected: three human weaknesses, two organizational contributing factors, the recommendation set aside for Lab 4.

Writing a risk factor statement

Pattern

Asset or process — condition (source, location)

Good: 'NAS-01 — the administrator password is stored in a text file readable by all staff (PT-2026-05, PT-01, line 28)'

- Poor: 'NAS-01 is insecure' — nothing verifiable
- Poor: 'NAS-01 needs **MFA**' — a recommendation
- Poor: names a person — describe the role
- Poor: 'high risk' — the level comes in Topic 5
- Rules: one condition · verifiable · no solution · no likelihood or impact yet

Step 6 — corroboration and confidence

✓ CONFIRMED

Two independent sources agree — PT-06 + NA-16 + MR-01 (FW-HQ portal)

! SINGLE

One source: keep, ask for a second — the Wi-Fi key label (PT-04)

× CONFLICT

Sources disagree — PT-05 vs the insurance questionnaire: record the conflict (KRF-23)

? UNKNOWN

Not examined — the limitations of step 2

Two documents written by the same person from the same data count as one source.

Step 7 — record, and severity is not risk

- Row = **ID** (identifier), references (document, finding, line), category, confidence, business owner, open question
- Positive observations are recorded as existing controls (they lower likelihood in Topic 5)
- The report's 'High' rates the weakness in general
- Kalmia's risk level = likelihood × impact on Kalmia's assets (Classes 10 and 11)

PT-2026-05 — existing controls

MFA on the two Microsoft 365 admin accounts

Microsoft 365 audit logging

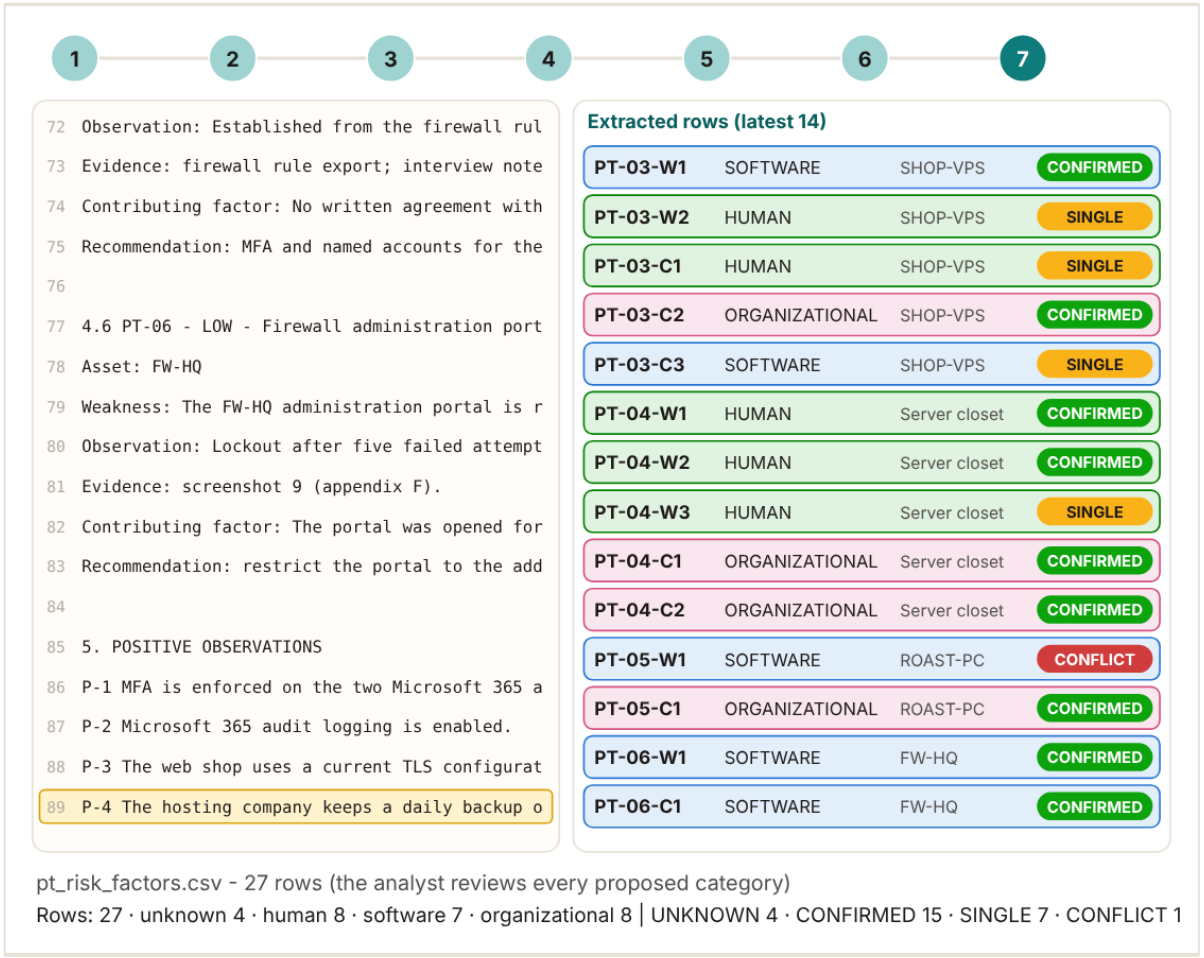
Current **TLS** (Transport Layer Security) on the web shop

Daily backup of SHOP-VPS by the host

Real-life example 3 — 27 rows from one report

Finding (tester's severity)	Weaknesses → category	Contributing factors → category	Confidence after step 6
PT-01 NAS-01 admin access (High)	Password in a readable file → human · **HTTP** (Hypertext Transfer Protocol) 5000 open to all → software	Shared account → human · no password manager, share permissions never reviewed → organizational	4 confirmed, 1 single
PT-02 Phishing simulation (High)	9 of 30 entered their password → human	No training, no reporting address → organizational · **MFA** on 2 accounts → software	2 confirmed, 2 single
PT-03 Web shop account guessed (High)	No **MFA**, no lockout → software · guessable seasonal password → human	Shared account → human · roles never reviewed → organizational · no password rules → software	2 confirmed, 3 single
PT-04 Server closet (Medium)	Visitor not challenged, key in the door, Wi-Fi key on a label → human	No visitor procedure, closet left unlocked for cleaners → organizational	4 confirmed, 1 single
PT-05 Vendor remote access (Medium)	Unattended access, shared password, no **MFA** → software	No written agreement with the vendor → organizational	1 conflict (insurance questionnaire), 1 confirmed
PT-06 FW-HQ portal (Low)	Portal reachable from the Internet → software	Opened for the **MSP** (managed service provider), never restricted → software	2 confirmed
Limitations L-1 to L-4	ROAST-PC, café networks, denial of service, no retest	—	4 unknowns

Code example 3 (Python) — extracting the risk factors



kalmia_report_extractor.py — the report read line by line (left) and the extracted rows with their confidence (right).

Videos — Lesson 3

Audits and Assessments — CompTIA Security+ SY0-701 (5.5) — 2:49 min

Professor Messer · https://www.youtube.com/watch?v=uo2Yw720mv4

Root Cause Analysis From Juran — 1:51 min

Juran Institute · https://www.youtube.com/watch?v=IETtnK7gzlE

Incident Response — CompTIA Security+ SY0-701 (4.8) — 9:14 min

Professor Messer · https://www.youtube.com/watch?v=X2UiMLxRdhE

Checked on November 10, 2026 — every video exists and is 15 minutes or shorter. Check each link on VirusTotal before opening it (Legal Notice, s. 14.2).

LESSON 4 · 0:50 – 0:58

4

Workshop: the list of risk factors for Kalmia

Rules of the list, consolidation of all sources, and the link to Lab 3

The workshop — task, columns and rules

Task (teams of 3–4)

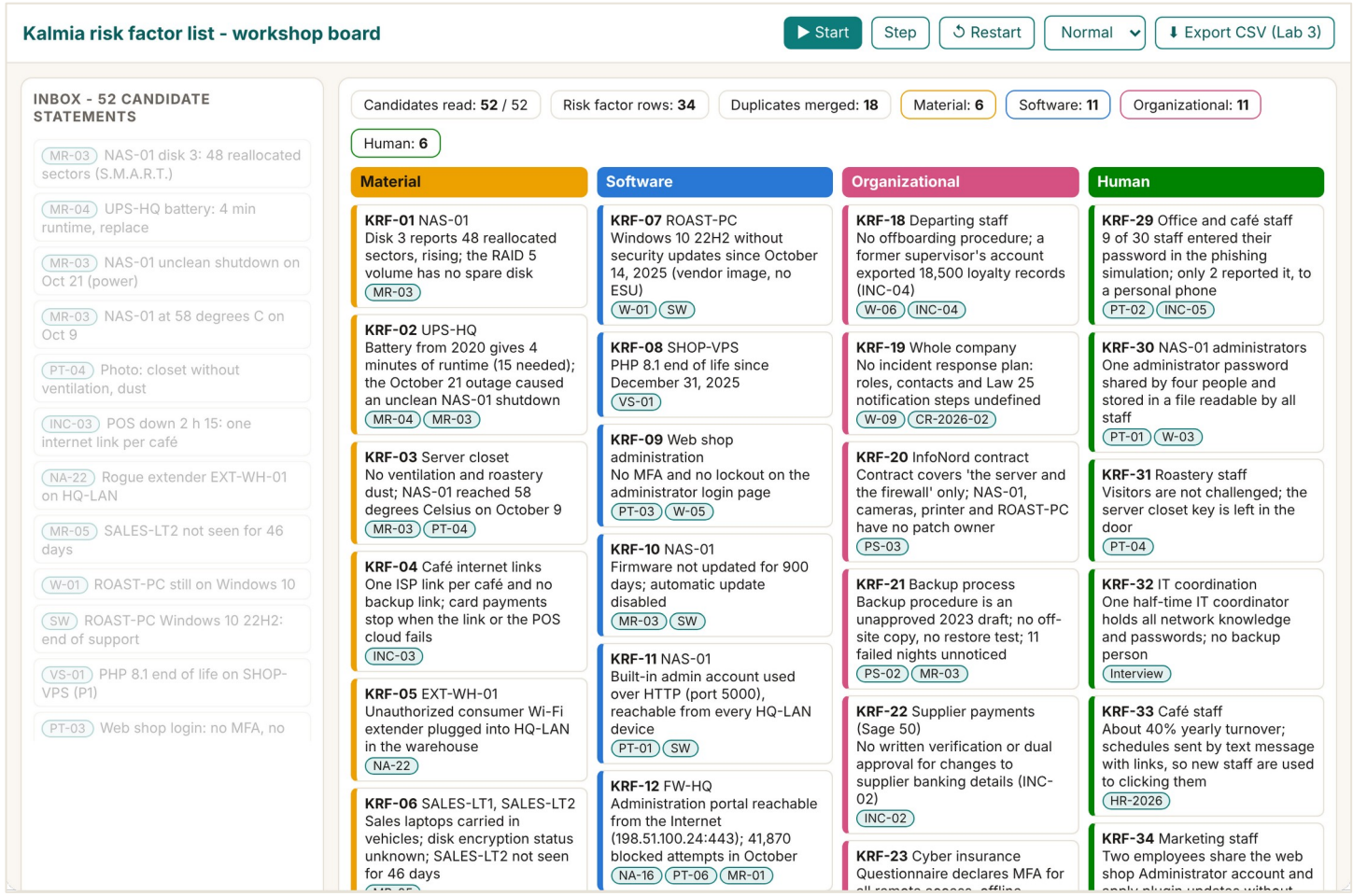
Inputs: Class 6 NA-, SW-, VS- rows + tonight's outputs + the evidence pack.

Output: one consolidated list.

Columns: **ID** (identifier) · asset · risk factor · category · type · sources · confidence · business owner · question.

- 1. One asset + one condition = one row; merge duplicates
- 2. Never lose a source
- 3. At least three rows per category
- 4. Keep unknowns visible
- 5. No likelihood, impact or solution yet
- 6. Confidential (s. 7.5)

Code example 4 (HTML) — the workshop board



*kalmia_workshop_board.html — 52 statements from 38 sources become 34 rows (18 merged); Export **CSV** (comma-separated values) feeds Lab 3.*

Kalmia risk factor list (1/3) — material and software

ID	Asset	Risk factor	Category	Confidence
KRF-01	NAS-01	Disk 3 failing (48 reallocated sectors); no spare disk	**Material**	**SINGLE**
KRF-02	UPS-HQ	Battery gives 4 min of the 15 needed; unclean **NAS** (network-attached storage) shutdown	**Material**	**CONFIRMED**
KRF-03	Server closet	No ventilation, dust; NAS-01 reached 58 °C	**Material**	**CONFIRMED**
KRF-04	Café internet links	One **ISP** (Internet service provider) link per café, no backup link	**Material**	**CONFIRMED**
KRF-05	EXT-WH-01	Unauthorized Wi-Fi extender plugged into HQ-LAN	**Material**	**CONFIRMED**
KRF-06	Sales laptops	Encryption unknown; SALES-LT2 not seen for 46 days	**Material**	**SINGLE**
KRF-07	ROAST-PC	Windows 10 without security updates since Oct 2025	**Software**	**CONFIRMED**
KRF-08	SHOP-VPS	PHP 8.1 end of life since Dec 31, 2025	**Software**	**CONFIRMED**
KRF-09	Web shop admin	No **MFA** (multi-factor authentication) and no lockout on the login page	**Software**	**CONFIRMED**
KRF-10	NAS-01	Firmware 900 days old; automatic update disabled	**Software**	**CONFIRMED**
KRF-11	NAS-01	Built-in admin over **HTTP** (Hypertext Transfer Protocol) 5000, open to all HQ-LAN	**Software**	**CONFIRMED**
KRF-12	FW-HQ	Admin portal on the Internet; 41,870 blocked attempts	**Software**	**CONFIRMED**
KRF-13	CAM-HQ-3 and -4	Factory passwords, Telnet, CVE-2017-7921	**Software**	**CONFIRMED**
KRF-14	Microsoft 365	**MFA** enforced on 2 of 31 accounts	**Software**	**CONFIRMED**
KRF-15	M365 commandes@	Legacy authentication (**IMAP** [Internet Message Access Protocol]) on commandes@	**Software**	**SINGLE**
KRF-16	ROAST-PC access	Unattended vendor access, shared password, no **MFA**	**Software**	**CONFIRMED**
KRF-17	HQ-LAN	Flat network: untrusted devices reach NAS-01	**Software**	**CONFIRMED**

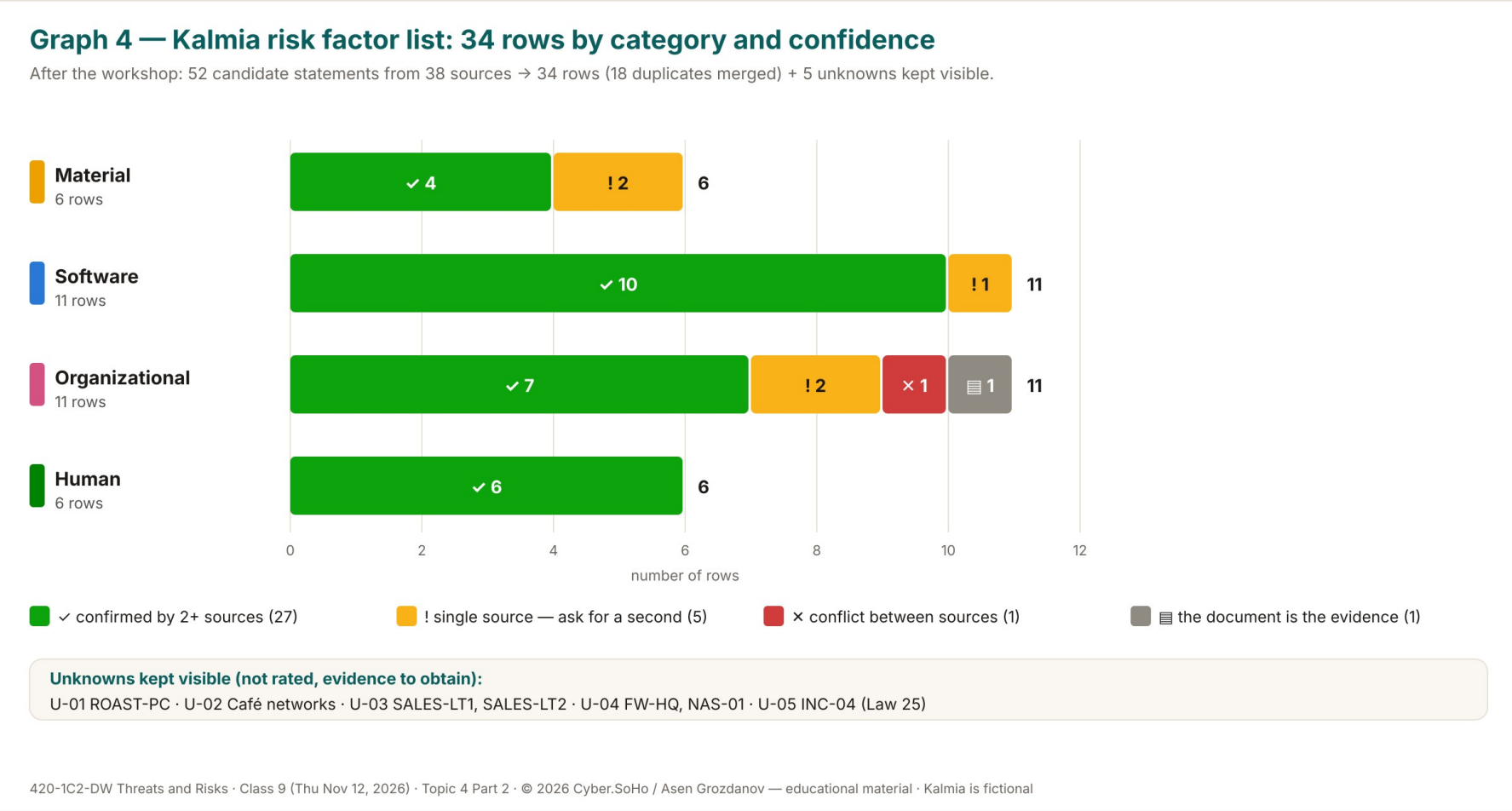
Kalmia risk factor list (2/3) — organizational

ID	Asset	Risk factor	Category	Confidence
KRF-18	Departing staff	No offboarding procedure (INC-04)	**Organizational**	**CONFIRMED**
KRF-19	Whole company	No incident response plan	**Organizational**	**CONFIRMED**
KRF-20	InfoNord contract	NAS-01, cameras, ROAST-PC have no patch owner	**Organizational**	**CONFIRMED**
KRF-21	Backup process	Draft procedure; no off-site copy; failures unnoticed	**Organizational**	**CONFIRMED**
KRF-22	Supplier payments	No verification or dual approval of bank changes	**Organizational**	**SINGLE**
KRF-23	Cyber insurance	Three declarations contradicted by the evidence	**Organizational**	**CONFLICT**
KRF-24	Law 25	No governance policy; person in charge not published	**Organizational**	**SINGLE**
KRF-25	Third-party access	No written agreement with the roaster vendor	**Organizational**	**CONFIRMED**
KRF-26	Change management	No test copy or approval rule; FW-HQ update waiting	**Organizational**	**CONFIRMED**
KRF-27	**IT** (information technology) policy (PS-01)	Never revised since 2019; personal devices on HQ Wi-Fi	**Organizational**	**DOCUMENT**
KRF-28	Remediation tracking	May findings still open; no owner or due date	**Organizational**	**CONFIRMED**

Kalmia risk factor list (3/3) — human and unknowns

ID	Asset	Risk factor / unknown	Category	Confidence
KRF-29	Office and café staff	9 of 30 entered their password; only 2 reported	**Human**	**CONFIRMED**
KRF-30	NAS-01 administrators	Admin password shared by four, stored in a file	**Human**	**CONFIRMED**
KRF-31	Roastery staff	Visitors not challenged; closet key left in the door	**Human**	**CONFIRMED**
KRF-32	**IT** coordination	One half-time coordinator, no backup person	**Human**	**CONFIRMED**
KRF-33	Café staff	About 40% turnover; schedule links sent by text	**Human**	**CONFIRMED**
KRF-34	Marketing staff	Shared web shop Admin account; untrained updates	**Human**	**CONFIRMED**
U-01	ROAST-PC	Never tested: excluded from the test, not managed	Unknown	**to obtain**
U-02	Café networks	Not covered by any test	Unknown	**to obtain**
U-03	Sales laptops	Disk encryption status unknown	Unknown	**to obtain**
U-04	FW-HQ, NAS-01	End-of-support dates missing	Unknown	**to obtain**
U-05	INC-04 (Law 25)	Serious-injury assessment not documented	Unknown	**to obtain**

Graph 4 — 34 rows by category and confidence



6 material · 11 software · 11 organizational · 6 human — 27 confirmed · 5 single · 1 conflict · 1 document · 5 unknowns.

Videos — Lesson 4



Risk Management — CompTIA Security+ SY0-701 (5.2)

3:30 min

Professor Messer · https://www.youtube.com/watch?v=cLhUMoQS1a8



Third-party Risk Assessment — CompTIA Security+ SY0-701 (5.3)

11:36 min

Professor Messer · https://www.youtube.com/watch?v=13KNjPexnEI



Risk Analysis — CompTIA Security+ SY0-701 (5.2)

9:13 min

Professor Messer · https://www.youtube.com/watch?v=Ykx7t54y-oo

Checked on November 10, 2026 — every video exists and is 15 minutes or shorter. Check each link on VirusTotal before opening it (Legal Notice, s. 14.2).

After tonight — what comes next

- Class 10 — Fri, Nov 13 — Topic 5 (Part 1): likelihood and impact scales; effects on confidentiality, integrity and availability
- Class 11 — Sat, Nov 14 — Topic 5 (Part 2): response capacity, risk matrix, risk register, prioritization
- Lab 2 — threat catalogue: due Sat, Nov 14, 23:59 ET, Léa drop box (Omnivox); tonight's risk factors can be cited as exposure facts
- Lab 3 — risk register (summary only): starts Nov 14, due Fri, Nov 20; each row of tonight's list is linked to a Lab 2 threat and rated on the Topic 5 scales
- Quiz 3 (Topics 1–5): Mon, Nov 16, online — created and administered separately

Hours 2 and 3 tonight

Run Code examples 1 to 4

Build your team's Kalmia risk factor list

Compare with the answer key after the first pass

Key references — and thank you

NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments https://csrc.nist.gov/pubs/sp/800/30/r1/final

NIST SP 800-115 — Technical Guide to Information Security Testing and Assessment https://csrc.nist.gov/pubs/sp/800/115/final

NIST SP 800-61 Rev. 3 — Incident Response Recommendations and Considerations for Cybersecurity Risk Management
https://csrc.nist.gov/pubs/sp/800/61/r3/final

NIST SP 800-92 — Guide to Computer Security Log Management https://csrc.nist.gov/pubs/sp/800/92/final

Act respecting the protection of personal information in the private sector (CQLR, c. P-39.1)
https://www.legisquebec.gouv.qc.ca/en/document/cs/P-39.1

Commission d'accès à l'information du Québec (CAI) https://www.cai.gouv.qc.ca

Canadian Centre for Cyber Security — Baseline cyber security controls for small and medium organizations
https://www.cyber.gc.ca/en/guidance/baseline-cyber-security-controls-small-and-medium-organizations

CIS Critical Security Controls v8.1 https://www.cisecurity.org/controls/v8-1

NIST SP 800-63B-4 — Authentication and Authenticator Management https://pages.nist.gov/800-63-4/sp800-63b.html

Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)
https://cyber-soho.github.io/prevmon/00.01.%20cyber.soho%20-%20legal.html

Thank you — questions? All links, with a VirusTotal check for each, are in the Links section of the lecture page.